Assignment 1

Huatai Pan, Rauf Muhammad

Course: NETAUTH – Network Security: Authentication and Authorization
Date: 23 September 2026
Scope: Isolated laboratory network 192.168.1.0/24 (lab systems only)

1 Introduction and Objective

The goal of this laboratory was to carry out an initial security assessment of a deliberately insecure internal web service. The assessment was performed from a Kali Linux virtual machine against an Ubuntu Server virtual machine on the same isolated network. The work covered network connectivity, service discovery, exploration of the web application and its access control, administrator credential testing, and analysis of the login traffic.

All activity was limited to the laboratory systems. The findings and conclusions below are based only on the evidence collected during the exercise.

2 Network Topology and Configuration

The laboratory consisted of two virtual machines on the same `/24` network, as shown in Table 1.

Table 1: Laboratory network configuration.

System	Role	IP address	Network
Kali Linux	Assessment client	192.168.1.5	192.168.1.0/24
Ubuntu Server	Target web server	192.168.1.35	192.168.1.0/24

On the Kali machine, interface `eth0` was assigned the address 192.168.1.5/24 with a directly connected route to 192.168.1.0/24, which placed both machines on the same isolated segment.

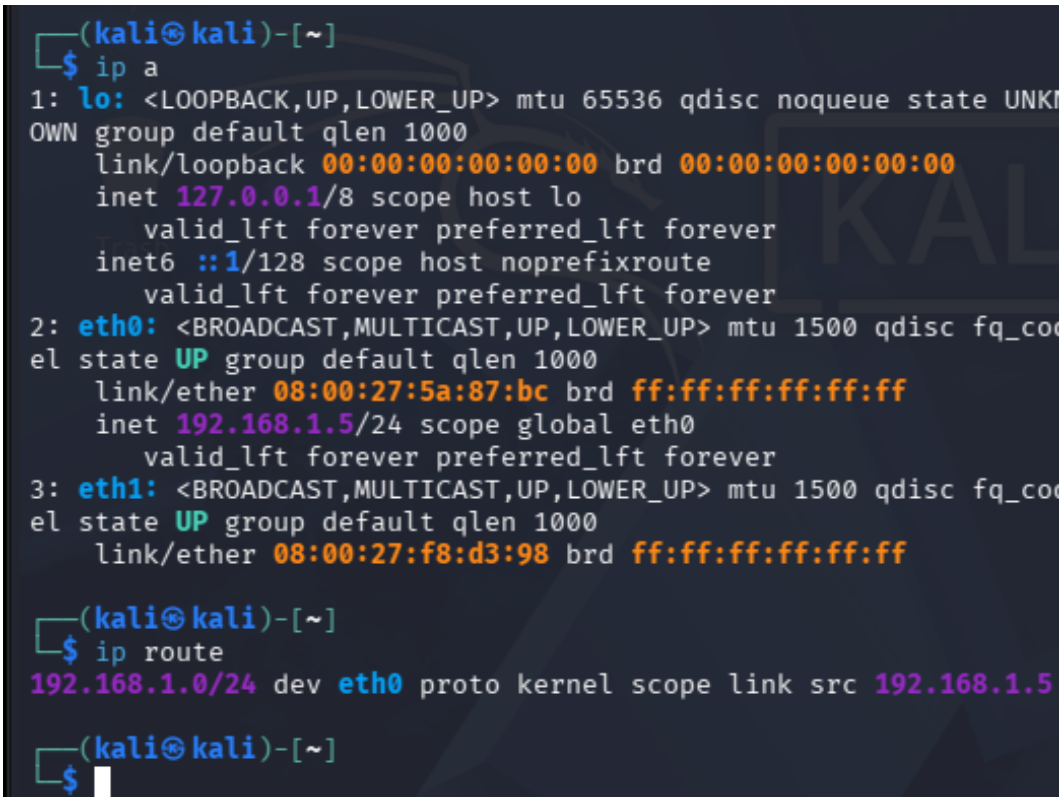


Figure 1: Kali Linux network configuration and route for 192.168.1.0/24.

3 Network Connectivity

Connectivity from Kali to the Ubuntu Server was checked with ICMP echo requests. The target 192.168.1.35 answered every request with 0% packet loss, which confirmed that the two machines could communicate before any further testing.

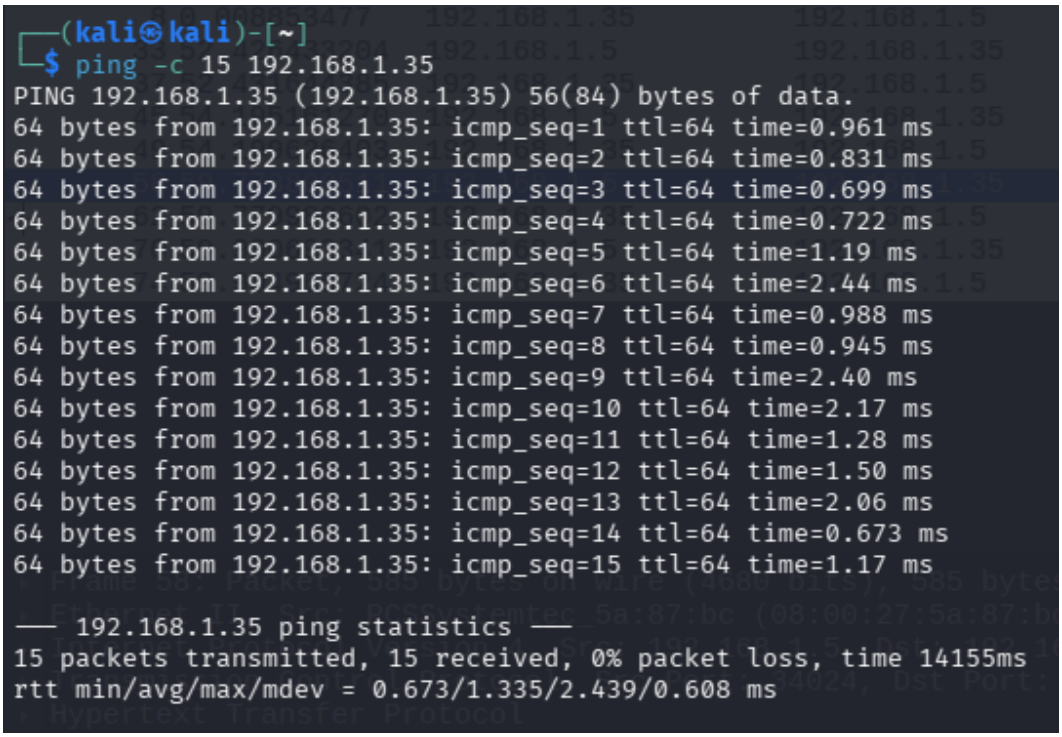


Figure 2: Successful ping test from Kali Linux to 192.168.1.35.

4 Service Discovery and Attack Surface

Nmap was used to identify the TCP services reachable on the Ubuntu Server. A version-detection scan found two open ports, summarised in Table 2.

Table 2: Open TCP ports found on 192.168.1.35.

Port	Service	Observed version / interpretation
22/tcp	SSH	OpenSSH 10.2p1 Ubuntu 2ubuntu3.6; remote administration service.
5000/tcp	HTTP	Werkzeug httpd 3.1.8 (Python 3.14.4); hosts the laboratory web application.

Both services are reachable over the network and therefore add to the attack surface. The scan alone does not prove that SSH is vulnerable; it only shows that SSH is an additional remotely accessible service that must be securely configured. Port 5000 exposes the web application examined in the next sections. It is also worth noting that the web application is served by Werkzeug, the development server built into Flask, which is not intended to be exposed as a production service and whose version is disclosed in the response.

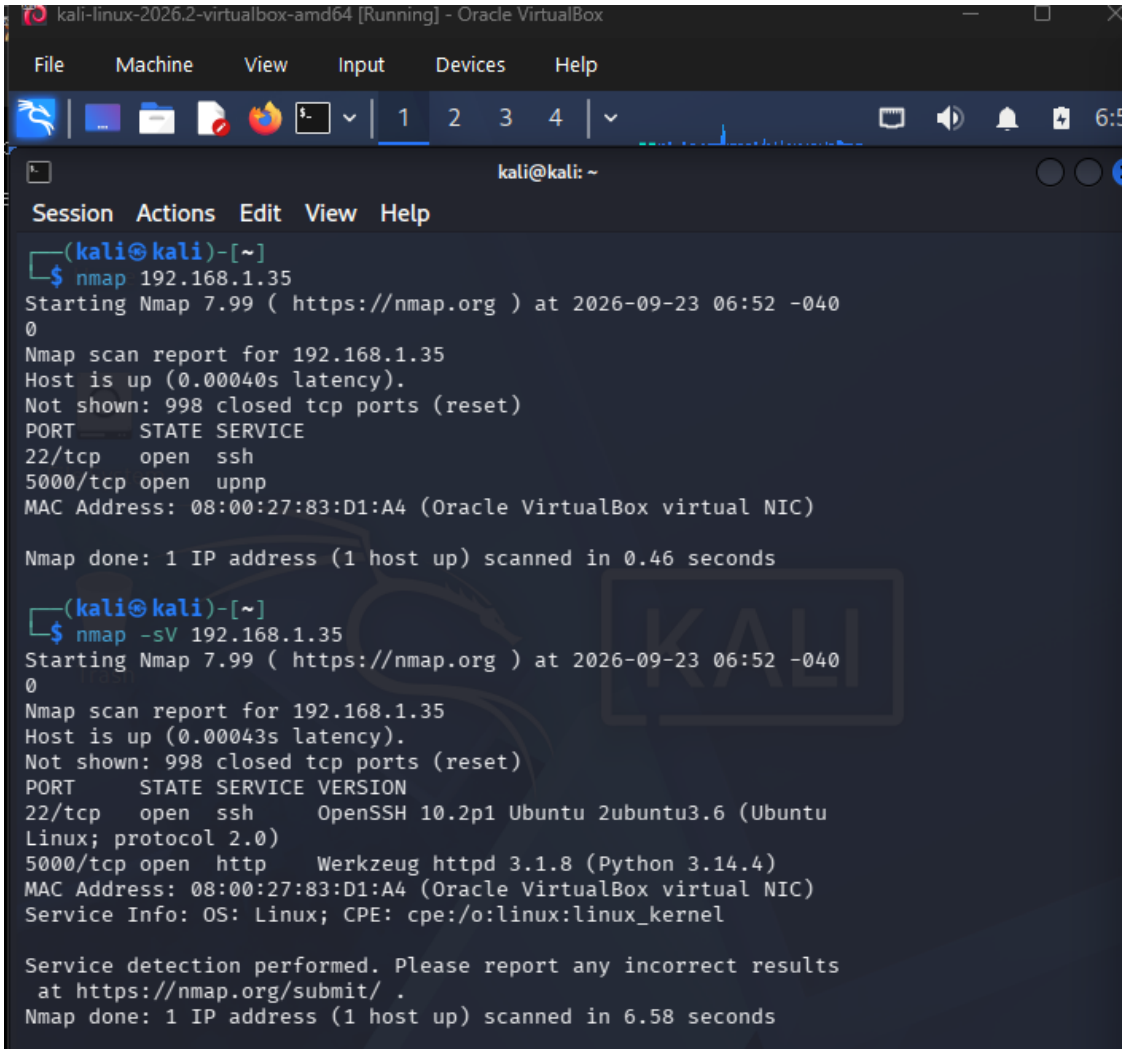


Figure 3: Nmap service-version scan against 192.168.1.35.

5 Web Application Exploration

5.1 Public resources

Before authentication, the root page at `http://192.168.1.35:5000/` reported that the user was not authenticated and offered links to *Public information* and *Login*. The landing page and the public-information page were both reachable without logging in, which is the expected behaviour for public content.

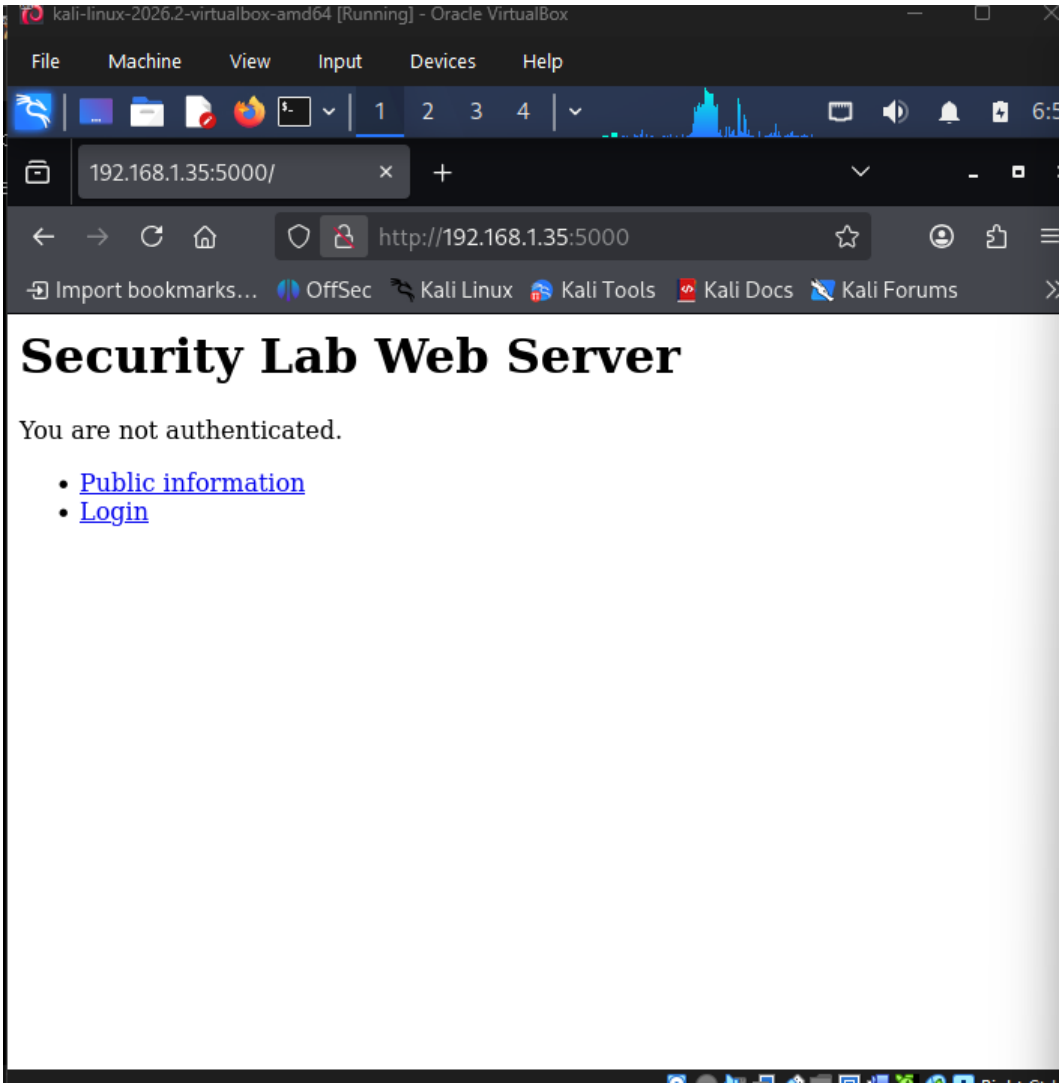


Figure 4: Web application landing page before authentication.

5.2 Authenticated employee access

The legitimate account `alice / alice123` was used to log in. After authentication, Alice was identified with the *employee* role and could open `/internal`. That page disclosed the internal network 192.168.1.0/24 and stated that the information should only be available to authenticated users. For an authenticated employee, this access is consistent with the stated policy.

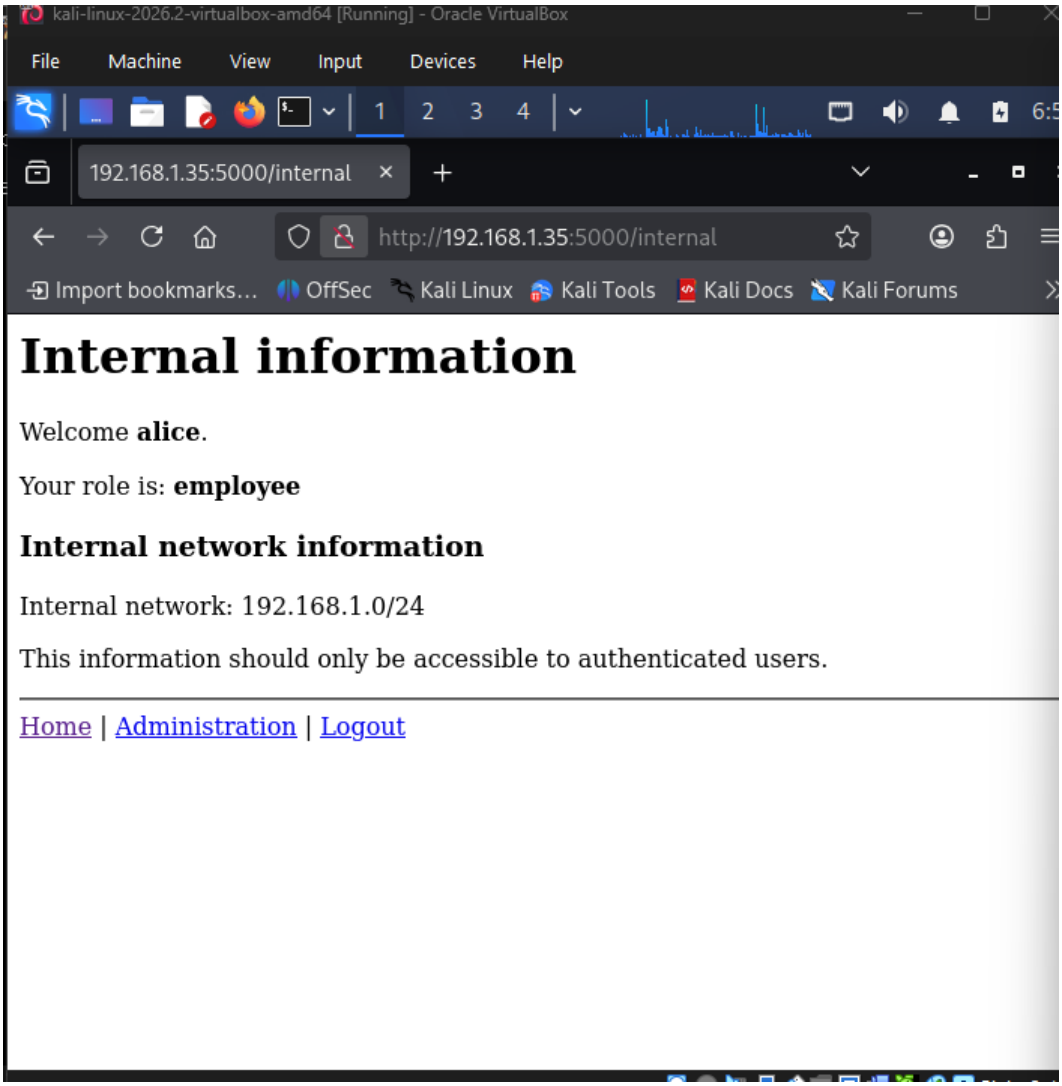


Figure 5: Alice authenticated as an employee and accessing `/internal`.

5.3 Unauthorised access to the administration page

While still logged in as Alice, the *Administration* link opened `/admin`. The page showed Alice's role as *employee* and, at the same time, stated that it should only be accessible to administrators. This is direct evidence that the application does not enforce role-based authorisation on the administrative resource: being authenticated is enough to reach it, regardless of the user's role.

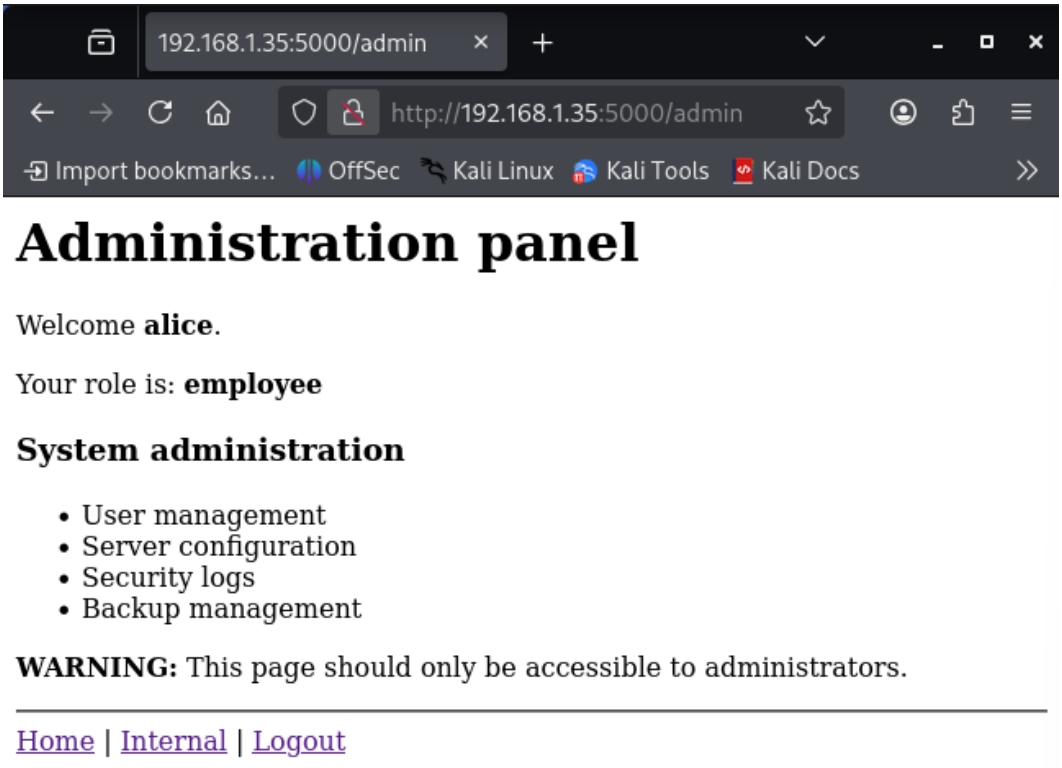


Figure 6: Employee user Alice accessing the Administration panel.

5.4 Administrator credential test

The administrator account was then accessed using the guessed credentials `admin / admin123`. The credentials followed the same predictable pattern as the other accounts and were accepted, giving a session identified as *admin*. The success of a simple, predictable password shows that administrator authentication is weak.

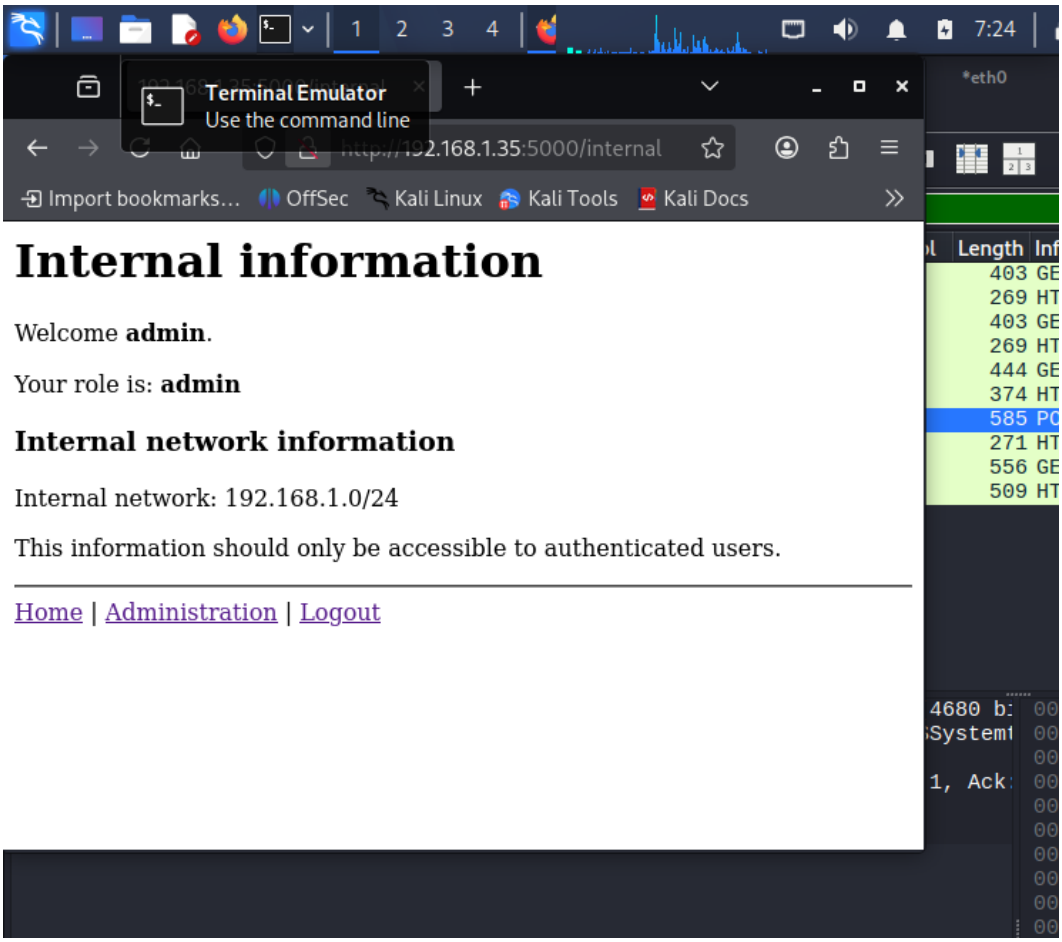


Figure 7: Successful administrator session using the guessed credentials.

6 Traffic Analysis

Wireshark was started on the Kali `eth0` interface, and Alice logged in again. Filtering the capture for the web traffic showed the login sequence: a `POST /login` request, an HTTP 302 redirect, and a following request for `/internal`.

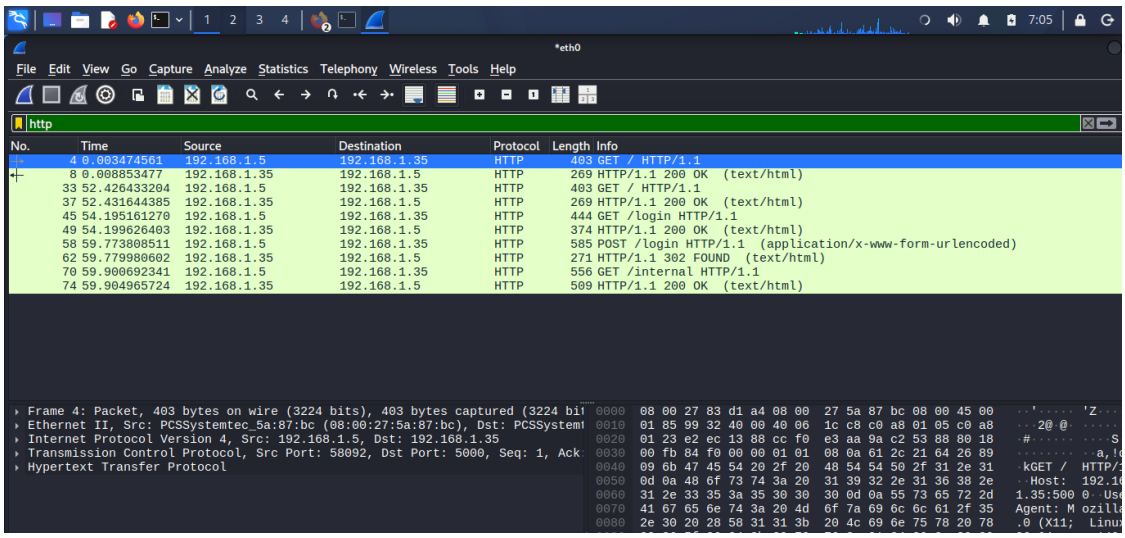


Figure 8: HTTP traffic showing `POST /login`, the redirect, and access to `/internal`.

Inspecting the `POST /login` packet showed that the request used `application/x-www-form-urlencoded` over plain HTTP. The form fields were readable directly in Wireshark: `username = alice` and `password = alice123`. The login credentials were therefore sent over the network without any transport encryption.

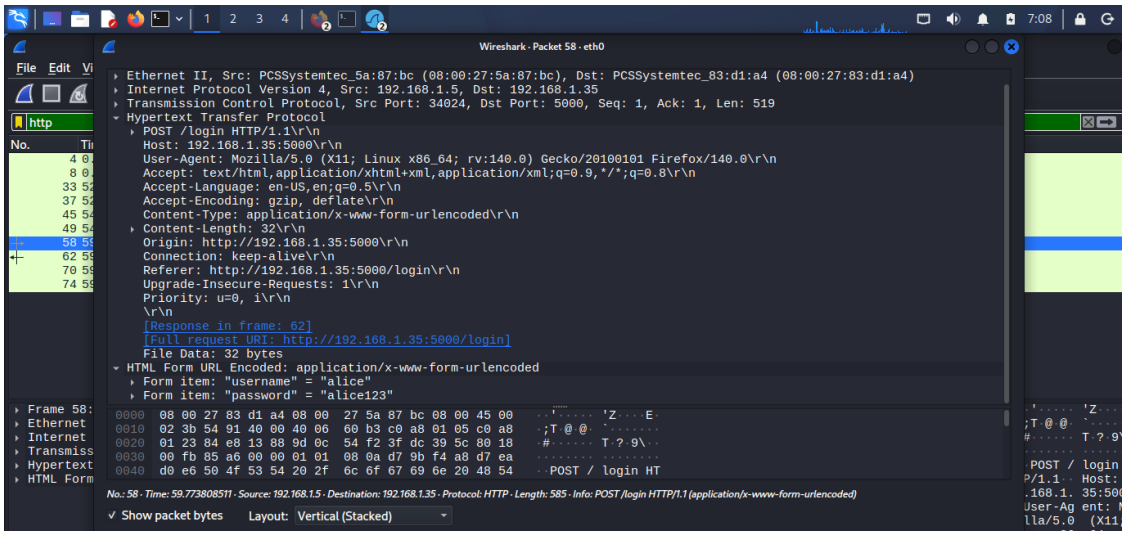


Figure 9: Wireshark packet details exposing Alice's username and password in the HTTP request.

7 Security Assessment

Each finding below follows the required *Observation* → *Security consequence* → *Countermeasure* structure and states the security properties affected. Only issues supported by the collected evidence are included.

7.1 Broken access control on `/admin`

Observation. Alice is authenticated with the *employee* role but can open the `/admin` page, which itself states that it should be restricted to administrators.
Security consequence. A non-administrator can reach administrative functionality and information. If the listed administrative functions were active, this could expose sensitive data or allow unauthorised configuration changes.
Affected properties. Authorization; Confidentiality; potentially Integrity.
Countermeasure. Enforce server-side role checks on every administrative endpoint. Authentication alone must not grant access; the server must confirm that the user holds the *admin* role before returning the page or performing any privileged action.

7.2 Weak and predictable administrator credentials

Observation. The administrator account was accessed using the guessed password `admin / admin123`, which follows the same obvious pattern as the other accounts.
Security consequence. An attacker who guesses the password gains administrator privileges and access to privileged resources, which undermines the authentication mechanism.
Affected properties. Authentication; Authorization; Confidentiality; potentially Integrity.

Countermeasure. Require strong, unique administrator passwords; forbid predictable or default-style passwords; add rate limiting or account lockout on repeated failures; and use multi-factor authentication for privileged accounts where possible.

7.3 Credentials transmitted in clear text over HTTP

Observation. Wireshark captured the `POST /login` request and showed the fields `username = alice` and `password = alice123` in readable form. The application was accessed over HTTP, not HTTPS.
Security consequence. Anyone able to observe the traffic can recover user credentials and reuse them to impersonate the user. Other HTTP content is also open to passive observation or modification in transit.
Affected properties. Confidentiality; Authentication; potentially Integrity of data in transit.
Countermeasure. Serve the application only over HTTPS with TLS, redirect HTTP to HTTPS, and apply secure session-cookie settings once TLS is in place.

7.4 Exposed network services increase the attack surface

Observation. Nmap found SSH on TCP/22 and the web service on TCP/5000 reachable from the Kali host, and both responses disclosed their software versions.
Security consequence. Each reachable service is an additional entry point. The scan alone does not prove an exploitable flaw, but unnecessary or weakly configured services increase the opportunities available to an attacker.
Affected properties. No direct violation was shown by the scan itself; a compromise of either service could affect Confidentiality, Integrity, or Availability.
Countermeasure. Expose only the services that are required, restrict access with host or network firewall rules, keep software updated, use strong authentication for SSH, and avoid exposing development web servers beyond the intended trusted network.

7.5 Summary of affected security properties

Table 3 maps each finding to the security properties it affects.

Table 3: Findings and affected security properties.

Finding	Conf.	Integ.	Avail.	Authn.	Authz.
Broken access control	Yes	Potential	–	–	Yes
Weak admin credentials	Yes	Potential	–	Yes	Yes
Plaintext HTTP credentials	Yes	Potential	–	Yes	–
Reachable SSH + HTTP services	Potential	Potential	Potential	Potential	Potential

8 Conclusion

The initial assessment shows that the service is reachable and working but has several important weaknesses. The most significant confirmed issues are broken authorisation on the administration

page, a predictable administrator password, and login credentials sent in clear text over HTTP. Together, these problems let a low-privilege user reach administrator-only content, make compromise of the administrator account easy, and expose user credentials to anyone capturing the network traffic.

The first priorities for remediation should be to enforce server-side authorisation on administrative resources, replace the weak administrator password with strong authentication controls, and serve all traffic over HTTPS/TLS. The exposed SSH and web services should also be hardened and limited to the systems that need them. Availability was not affected during the laboratory activities.

A Evidence Checklist

Table 4 maps each required deliverable to its location in this report.

Table 4: Required deliverables and where they appear.

Required deliverable	**Location**
Network topology and configuration	Section 2, Fig. 1
Connectivity evidence	Section 3, Fig. 2
Reconnaissance results and interpretation	Section 4, Fig. 3
Resources discovered in the web application	Section 5, Figs. 4–7
Wireshark evidence of the authentication exchange	Section 6, Figs. 8–9
Identified vulnerabilities and affected properties	Section 7
Proposed countermeasures	Section 7
Security-posture conclusion	Section 8